LABORATUVAR 3 · SCHNITZER 2×2 · CNC Ahşap Torna

# Threat & Risk + Risk Matrix

Çıktı: Risk Register

| Ad Soyad | Öğrenci No | Grup | Tarih |
|---|---|---|---|
| Yusuf Kaymaz | 230541084 | Gündüz-B | 23.10.2026 |

**Kavram:** Senaryo beş parçadır: kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç. Skor = L × S × E (her biri 1–3). Kural: S=3 ise skor düşük olsa bile senaryo öne alınır, insana zarar görünür kalır.
**Schnitzer'in kapıları (Lab 2 envanterinden):** B-1 uzak destek bağlantısı · D-10 / B-3 USB portu · D-9 Ethernet · H-1 CNC varsayılan erişim parolaları · H-2 ortak CAM PC hesabı · V-3 servis dizüstüsü / güncelleme dosyaları. Fiziksel sonuç adayları: dönen parçaya dolanma, fırlayan parça, kesilme, sıkışma.

## Görev — senaryo kurun ve puanlayın

| ID | Senaryo (kim → kapı → zincir → fiziksel sonuç) | L | S | E | Skor | Öncelik |
|---|---|---|---|---|---|---|
| **R-01** | **Fırsatçı dış** → internete açık uzak destek (B-1, paylaşılan parola) → CAM PC → Ethernet ile 808D'de iş mili azami hız parametresi yükseltilir → **SF-4 bozulur**, kütük fazla hızda çatlayıp fırlar → operatöre çarpma, ağır yaralanma | 3 | 3 | 3 | **27** | **1 · Kritik** |
| **R-02** | **Meraklı içeriden** → CNC varsayılan erişim parolası (H-1) → "parça yüklemesi yavaş" diyerek kapak açıkken harekete izin veren ayarı açar → **SF-2 bozulur** (kapak mantığı CNC'de ise, VS-3) → dönen parçaya kol/kıyafet dolanır, ağır yaralanma | 3 | 3 | 1 | **9** | **2 · Yüksek** |
| **R-03** | **Tedarik zinciri** → servis dizüstüsü / imzasız güncelleme (V-3) → değiştirilmiş PLC programı punta basınç kontrolünü atlar → **SF-3 bozulur**, basınç düşükken iş mili döner → parça puntadan kurtulup fırlar, ağır yaralanma | 1 | 3 | 1 | **3** | **3 · Düşük ⚑ S3 bayrağı** |
| **R-04** | **Fırsatçı dış** → uzak destek (B-1) → CAM PC fidye yazılımıyla şifrelenir → program arşivi kaybolur, üretim durur → kimse yaralanmaz (emniyet bulgusu değil) | 3 | 1 | 3 | **9** | **4 · Yüksek (S=1)** |

Bantlar: **Kritik 18–27** · **Yüksek 9–17** · **Orta 4–8** · **Düşük 1–3**

### Puan gerekçeleri

| ID | L gerekçesi | S gerekçesi | E gerekçesi |
|---|---|---|---|
| R-01 | Paylaşılan parola, otomatik tarama ve hazır araçla dakikalar içinde girilir | Fırlayan parça ağır ya da kalıcı yaralanma yapar | Bağlantı internetten sürekli açık |
| R-02 | Varsayılan parola, makine başında herkes deneyebilir | Dolanma ağır ve kalıcı yaralanma yapar | Yalnızca makine başından, fiziksel erişimle |
| R-03 | Tedarikçi altyapısını ele geçirmek gerekir, birden çok adım var | Fırlayan parça ağır yaralanma yapar | Sadece servis ziyaretinde, fiziksel bağlantıyla |
| R-04 | R-01 ile aynı kapı, aynı L | Sadece üretim ve veri kaybı, yaralanma yok | R-01 ile aynı kapı, aynı E |

**1** **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

**R-01 (27, Kritik):** kapı internete sürekli açık ve paylaşılan parolayla dakikalar içinde istismar edilebilir; zincir iş mili hız sınırını bozup fırlayan parçayla operatörü ağır yaralar.

**2** **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet, **R-03 (L1 · S3 · E1 = 3, Düşük).** Risk Register'da **S3 bayrağıyla** işaretleyip ayrı S3 listesinde yönetime raporluyoruz. Skoru 9 olan ama kimseyi yaralamayan R-04'ün (fidye) **önüne** aldık. Bir önlem (imzalı güncelleme + değişiklik sonrası safety validation: kapak, E-stop ve punta testleri) ya da yazılı kabul kararı olmadan kapatılmaz.

> **Altın kural:** Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir. Bir adım daha gidin: bu, makinedeki insana ne yapar? R-04 bu yüzden S=1 aldı. Fidye sonrası operatör kontrolsüz eski bir programı USB ile yüklerse zincir fiziksele uzar, o zaman R-04 yeniden puanlanır.

## Ek sorularımız

**3** **R-01'in bugünkü ve önlemli hâli nasıl puanlanır?** EK SORU

| Durum | Önlemler | L · S · E | Skor |
|---|---|---|---|
| **Bugün** | Mevcut hâl (VS-3, VS-4) | 3 · 3 · 3 | **27 · Kritik** |
| **Erişim önlemleri** | Jump server, VPN, MFA, kişisel hesap, varsayılan kapalı, C3'te parametre yazma kapalı | 1 · 3 · 2 | **6 · Orta** (S3 bayrağı sürer) |
| **+ Emniyet bağımsızlığı** | Hız sınırı CNC parametresinden bağımsız, emniyet sınıfı bir fonksiyonda | 1 · 1 · 2 | **2 · Düşük** |

Erişim önlemleri L ve E'yi düşürür, S'yi ise yalnızca emniyet tasarımı düşürür. Bunun tasarımını Lab 4'te yaptık.

**4** **Emniyete hiç dokunmayan bir siber senaryo (R-04) Register'a girmeli mi?** EK SORU

Evet, girmeli ama **S=1 ile ve emniyet bulgusu olarak değil.** R-04 bize iki şey söylüyor. Birincisi, R-01 ile aynı kapıyı kullanıyor, yani o kapıyı kapatmak iki riski birden düşürür. İkincisi, üretim baskısı elle müdahaleyi artırır. Matris bir araçtır, patron değil: R-04'ün skoru R-03'ten yüksek olsa da öncelik R-03'te.

### Eylem planı (Risk Register'ın yönetim kolonu)

| ID | Önerilen önlem | Sahip (RACI) | Hedef |
|---|---|---|---|
| R-01 | Uzak erişimi kapat, jump server + VPN + MFA kur, C3'te parametre yazmayı kapat | A: Yönetim · R: OT + IT | 30 gün (Kritik) |
| R-02 | Varsayılan parolaları değiştir, erişim seviyelerini ayır, kapak mantığını safety zincirine taşı | A: Yönetim · R: Safety + Servis | 90 gün |
| R-03 | İmzalı güncelleme, servis dizüstüsü kontrolü, değişiklik sonrası safety validation | A: Yönetim · R: Servis + Safety | S3 listesi, yönetime rapor |
| R-04 | CAM PC yedekleme + çevrim dışı program arşivi, CAM PC'de web / e-posta yok | A: Yönetim · R: IT | Planlı iyileştirme |

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur. Durum: **Taslak**.